# CANTO INCOGNITO / POELLM

GitHub poem-based C2 discovery from compromised AI infrastructure

- HUNTING / MEDIUM CONFIDENCE
- MICROSOFT DEFENDER XDR
- T1102.003 / CAMPAIGN ARTIFACT
- Published 11 October 2026

# EXECUTIVE ASSESSMENT

Decision

- Black Lotus Labs tracked PoeLLM from April 2026 across more than 3,400 affected servers.
- The malware retrieves a poem stored as dash.css in a GitHub repository and decodes four words into the current C2 IPv4 address.
- The repository identity and file name are source-observed and more durable than the rotating C2 IP list.
- Operational value: 8/10. Hunt only; RemoteUrl path population must be validated per tenant.

# BEHAVIOR & EVIDENCE

Confirmed observations

- PoeLLM targets exposed LiteLLM, Ollama, Gotenberg and Gitea services; Ivanti Sentry may also have been targeted.
- Compromised systems mine cryptocurrency and are reused as scanners and exploit servers.
- The poem was first committed on 13 April 2026 and changed 11 times while retaining the same extraction grammar.
- Black Lotus Labs inspected malware sample SHA-256 6fab94577364beec314afae3b082dd680933f08a8349b9f35b92667e8231b501.
- No endpoint execution outcome is inferred from a GitHub fetch match.

# TELEMETRY CONTRACT

Required evidence

- Required: Microsoft Defender for Endpoint network events from onboarded Linux or other covered workloads.
- Documented fields: Timestamp, DeviceName, RemoteUrl, RemoteIP, RemotePort, Protocol and initiating-process context.
- Correlation key: DeviceName plus Timestamp plus ReportId identifies the event; process context supports triage.
- Optional: cloud workload inventory, container identity, exposure data, DNS, proxy and file telemetry.
- Gap: RemoteUrl can be an FQDN rather than a full URL; HTTPS content and response body are not inferred.

# HUNTING LOGIC

Primary KQL

```
DeviceNetworkEvents
| where RemoteUrl has "ejejejdfbbebe"
| where RemoteUrl endswith "dash.css"
| project Timestamp, DeviceName, RemoteUrl, RemoteIP, RemotePort, Protocol,
InitiatingProcessFileName, InitiatingProcessCommandLine,
InitiatingProcessFolderPath, InitiatingProcessSHA1,
InitiatingProcessAccountName, ReportId
| order by Timestamp desc
```

# TRIAGE

Investigation path

- Confirm that RemoteUrl contains the full path and preserve the raw event.
- Validate whether the host runs an exposed AI, PDF-conversion, development or edge service named in the research.
- Inspect the initiating process, executable path, hash, account, container and parent process.
- Hunt for subsequent connections to ports 3778, 5001, 5002 or 9999 and for mining or scanning behavior.
- Do not treat GitHub access alone as proof of infection; establish process and workload provenance.

# FALSE POSITIVES & VALIDATION

Promotion gates

- Likely benign overlap is low, but security research, sandboxing or IOC collection may access the repository.
- Success: a controlled fetch populates the repository account and dash.css path in RemoteUrl with process context.
- Reject: the sensor records only github.com/raw.githubusercontent.com or legitimate research activity dominates.
- Failure: the workload is not onboarded, container network events are absent, or a proxy strips the URL path.
- No threshold, rarity score, join or sequence is used.

# CONCLUSION & REFERENCES

Analytical conclusion

- Classification: Hunting query - Untested implementation sketch. Confidence: Medium.
- Primary: Black Lotus Labs, Canto incognito: tracking the PoeLLM malware, 7 October 2026.
- Schema: Microsoft Learn, DeviceNetworkEvents, last updated 22 June 2026.
- ATT&CK: T1102.003 Web Service: One-Way Communication.
- Secondary SIEM mappings are withheld until parser and field population are verified.
- Source URLs are defanged in references.txt. No customer data is included.